SentinelIQ 02 — Product Requirements (PRD)

Oct 13, 2026 · @maxi

Version 1 delivers eight must-have capabilities (FR1–FR8); every other idea is deferred or listed as a non-goal.

Must-have requirements

Each requirement has an ID that later documents, tests and commits will reference.

ID	Requirement	Acceptance criterion
FR1	Register and log in with JWT; roles are analyst, lead and admin	A user without the right role receives HTTP 403 on a protected route
FR2	Ingest events through an API, one at a time or in batches, with schema validation and deduplication	Sending the same event twice stores it once; an invalid event is rejected with a clear error
FR3	Normalize events from every source into one internal schema	Both data sources produce rows with identical columns
FR4	Score each event for anomaly risk with an ML model; store the score and model version	Every stored event has a score, a model version and a timestamp
FR5	Generate an explanation for events above a threshold that retrieves ATT&CK techniques and cites them	Each explanation lists its retrieved technique IDs and source passages
FR6	Analyst dashboard with a prioritized queue, event detail, and the explanation beside the raw data	An analyst can open the highest-risk event in two clicks from login
FR7	Analyst actions (confirm, dismiss, escalate) with a required note, saved to an immutable audit log	Audit rows cannot be edited or deleted through the API
FR8	Metrics view: alert volume, false-positive rate and time to decision	Figures on screen match a direct database query

Should-have requirements

These are built only after all must-have items pass their acceptance criteria.

ID	Requirement	Why it matters
SH1	Dedicated message queue (Redis) in place of the database job table	Keeps the ingestion API fast under load
SH2	Search, filters and CSV export on the alert queue	Real analysts need to slice the queue
SH3	Feedback loop: analyst decisions saved as labels for retraining	Shows how the system improves over time
SH4	Admin screen for users and roles	Completes the access-control story

Analyst workflow

The workflow below is the path every v1 feature must support.

1. An event arrives through the ingestion API and is validated, deduplicated and normalized (FR2, FR3).
2. The scoring service assigns a risk score and stores the model version (FR4).
3. If the score is above the threshold, the triage service retrieves ATT&CK techniques and writes a cited explanation (FR5). Below the threshold, the event is stored but not queued.
4. The analyst opens the prioritized queue and selects an event (FR6).
5. The analyst reads the explanation next to the raw data and chooses one of three actions: confirm, dismiss or escalate (FR7).
6. The decision and the analyst's note are written to the audit log, and the metrics view updates (FR7, FR8).

Non-goals

Stating these early prevents scope creep and shows judgment.

- No connection to live company infrastructure or real customer data.
- No automated blocking, quarantine or remediation of any kind.

- No claim of replacing or outperforming commercial SIEM products.
- No multi-tenant billing, SSO integrations or mobile app in v1.
- No fine-tuning of a large language model; v1 uses retrieval over a curated ATT&CK knowledge base instead.

Decisions

These four early decisions were made on 13 October 2026. Change one here first, then update the documents it affects.

Decision	Choice	Reason
Data sources	Public network flows plus synthetic authentication logs	Covers the ML layer and the identity-based story, and forces a real normalization design
Deployment	Docker-only through Phase 6; Google Cloud Run in Phase 7	Keeps early progress unblocked and still ends with a live link
LLM provider	Hosted API behind a small interface	Fastest for v1; the interface lets a local model be swapped in later
Alert threshold	Configurable, with a fixed default for the demo	Matches how SOC teams tune alerting, and keeps the demo predictable